

인공지능(AI) 보안 안내서 정오표

① p.17 (가독성을 위하여 18페이지 상단 표를 17페이지로 이동)

기존		
(p.17~18)		
※ 주요 해외 참고자료		
17		
인공지능(AI) 보안 안내서		
주관	명칭	특징
(미국) NIST	AI Risk Management Framework(AI RMF 1.0), 2023.1	글로벌 표준
(미국) ISO/IEC	ISO/IEC 42001	인증
	ISO/IEC 23894	AI에 특화
(미국) OWASP	OWASP Top 10 for LLM Applications (Ver 1.1)	개발 보안
(미국) Google	Google SAIF	개발 보안
EU	EU AI ACT	규제
OECD	OECD AI 원칙	정책 권고
(싱가폴) 정보통신부	Model AI Governance Framework, 2020	생성형 AI
(영국) NCSC	Guidelines for secure AI system development, 2023.11	가이드라인
(일본) 총무성·경제산업성	AI 사업자 가이드라인(제1.0판), 2024. 6	

(p.17)

⑤ 개발자 대상 「인공지능(AI) 보안 안내서」의 활용 방안

- 「인공지능(AI) 보안 안내서」는 AI 제품 및 시스템 개발 현장에서 보안(Security) 관련 공격을 받거나 받을 우려가 있는 경우 데이터 과학자, 모델 개발자 등이 실제로 취해야 할 조치 사항으로 활용할 수 있다.
- 「인공지능(AI) 보안 안내서」의 요구사항 및 검증항목 점검주체는 조직의 구성원 개인을 의미하는 경우도 있으나, 조직의 부서(예컨대, 개발팀) 내지 조직 자체(예컨대, AI 소프트웨어 개발회사)를 가리키는 경우도 있다. 예를 들어, 모델 학습을 진행하는 환경이 안전하게 보안조치 되어 있는지 여부를 파악하기 위해서는 물리적 보안 외에도 방화벽·VPN 등 네트워크 보안도 함께 봐야 한다.(3.1.1. 참고) 이 경우 해당 보호조치는 개발자 개인이 아니라 전사적 차원에서 수행해야 할 업무이다. 반면에 개발자는 직무 관련 교육을 연간 100시간 이상 받아야 한다면 이 업무는 개발자 개인이 1차적인 수행주체가 된다. 「인공지능(AI) 보안 안내서」에서는 요구사항 및 검증항목에 대한 개인과 조직의 역할을 분명하게 인식할 수 있도록 해당 항목의 이행주체를 명시하였다.
- 다만, 본 안내서는 대외적으로 법적 효력을 가지는 것이 아니므로 본문의 기술 방식(‘~해야 한다.’ ‘필수적이다’ 등)에도 불구하고 참고로만 활용하기 바란다.

⑥ 안내서 작성 과정 및 참고 자료

- 2024년 6월부터 「AI 보안 정책 포럼」을 구성하여 운영하였고, 그 외에도 다양한 의견을 수렴하는 과정을 거쳤다. 초안 작성한 후, 학계 및 산업계 전문가 등의 의견수렴을 거쳐 <AI 개발자를 위한 보안 요구사항 및 검증항목> 최종본을 마련하였다.
- 미국, 유럽, 일본 등 해외기관에서 발표한 원칙 및 프레임워크 등을 참조하였고, 국내자료로는 과학기술정보통신부/한국정보통신기술협회(TTA)에서 발간한 「신뢰할 수 있는 인공지능 개발 안내서」, 국가정보원/국가보안기술연구소에서 발간한 「챗GPT 등 생성형 AI 활용 보안 가이드라인」, 금융보안원에서 발간한 「금융분야 AI 보안 가이드라인」 등도 참고하였다.

※ 주요 해외 참고자료

주관	명칭	특징
(미국) NIST	AI Risk Management Framework(AI RMF 1.0), 2023.1	글로벌 표준
(미국) ISO/IEC	ISO/IEC 42001	인증
	ISO/IEC 23894	AI에 특화
(미국) OWASP	OWASP Top 10 for LLM Applications (Ver 1.1)	개발 보안
(미국) Google	Google SAIF	개발 보안
EU	EU AI ACT	규제
OECD	OECD AI 원칙	정책 권고
(싱가폴) 정보통신부	Model AI Governance Framework, 2020	생성형 AI
(영국) NCSC	Guidelines for secure AI system development, 2023.11	가이드라인
(일본) 총무성·경제산업성	AI 사업자 가이드라인(제1.0판), 2024. 6	

- ② p.25 (기존의 인쇄·편집 과정에서 누락된 3.4.8 추가)
(정오 수정전 AI 보안 안내서 : p.26)

(항목 추가)					
3.4.8 LLM의 벡터 및 임베딩 취약점에 대한 방어 방안을 수립하고 있는가?					
생명주기	요구사항 및 체크리스트	개발자		AI 유형	
		담당자	조직	Pred AI	Gen AI
3 모델개발 (학습/ 모델링/ 검증)	3.1 학습/검증 환경에 대한 보안(Secure Training Environment)				
	3.1.1 모델 학습을 진행하는 환경이 안전하게 보안조치 되어 있는가?	○	○	○	○
	3.1.2 학습 또는 검증 단계에서 악의적인 사용자가 허위 데이터를 삽입할 가능성을 차단하고 있는가?	○		○	○
	3.1.3 연합 학습(Federated Learning)에 참여하는 장치 중 악의적인 장치가 있는지 검증하고 있는가?	○		○	○
	3.2 모델 공격에 대한 방어				
	3.2.1 AI Prompt Injection 공격에 대한 방어 방안을 수립하고 있는가?	○			○
	3.2.2 적대적 예제 공격 (Adversarial Example Attacks)에 대한 방어 방안을 수립하고 있는가?	○		○	○
	3.2.3 모델 회피 공격(model evasion attack)에 대한 방어 방안을 수립하고 있는가?	○		○	○
	3.2.4 모델 오염 공격(Model Poisoning Attack)에 대한 방어 방안을 수립하고 있는가?	○		○	○
	3.2.5 모델 추출 공격(model extraction attack) 및 리버스 엔지니어링에 대한 방어 방안을 수립하고 있는가?	○		○	○
	3.2.6 반복적인 질의에 대한 방어 방안을 수립하고 있는가?	○			○
	3.2.7 기계 학습을 활용한 모델 공격에 대해 능동적으로 방어하고 있는가?	○		○	○
	3.3 오픈소스 라이브러리 보안				
	3.3.1 오픈소스 라이브러리의 업데이트 및 취약점을 관리하고 있는가?	○		○	○
	3.3.2 오픈소스 라이브러리의 소스 코드를 직접 검토하거나 사용에 대한 보안 문제를 검증하고 있는가?	○		○	○
	3.3.3 오픈소스 라이브러리를 실행할 때 잠재적인 보안 위험을 제거하기 위해 격리된 환경을 이용하고 있는가?	○		○	○
	3.4 LLM 보안				
	3.4.1 LLM 애플리케이션 공격에 대한 예방책을 마련하고 있는가?	○			○
	3.4.2 LLM의 모델 서비스 거부(Model Denial of Service) 공격에 대한 방어 방안을 수립하고 있는가?	○			○
	3.4.3 LLM의 API 보안을 위한 방안을 수립하고 있는가?	○			○
	3.4.4 LLM의 인터페이스 공격에 대한 예방책을 마련하고 있는가?	○			○
	3.4.5 개발 환경에서 LLM을 사용할 때 잠재적인 취약성의 통합을 방지하기 위한 안전한 코딩 관행과 지침을 수립하고 있는가?	○	○		○
	3.4.6 LLM 출력결과를 정기적으로 모니터링하고 검토하고 있는가?	○			○
	3.4.7 LLM의 Prompt Injection 공격에 대한 방어 방안을 수립하고 있는가?	○			○
	3.4.8 LLM의 벡터 및 임베딩 취약점에 대한 방어 방안을 수립하고 있는가?	○			○

- ③ p.54 (기존의 인쇄·편집 과정에서 누락된 항목 3.4.7 추가)
(정오 수정전 AI 보안 안내서 : p.55)

3.4.7 LLM의 Prompt Injection 공격에 대한 방어 방안을 수립하고 있는가?

YES ☐ NO ☐ N/A ☐

- "Prompt Injection"은 공격자가 정교하게 설계된 입력을 통해 LLM(Large Language Model)의 동작이나 출력을 조작하여 의도하지 않은 결과를 유도함. 유형으로 ▲직접 프롬프트 인젝션 ▲간접 프롬프트 인젝션, ▲다중 모달 및 언어 기반 인젝션 등이 있음
- "Prompt Injection"은 출력을 조작하여 의도하지 않은 결과 유도, AI 탈옥 또는 모델 탈취 등을 발생시킬 수 있음
- "Prompt Injection"은 LLM 애플리케이션의 보안을 위협할 수 있는 가장 흔한 공격으로, 다양한 애플리케이션에서 발생 가능하며, 방어가 까다롭기 때문에 지속적인 모니터링과 보안 대책이 필수

"Prompt Injection"에 대한 예방책

방어 기법	세부 내용
모델 동작 제한	모델의 역할, 기능, 한계에 대한 구체적인 지침을 설정. 응답을 특정 작업이나 주제로 제한하며, 핵심 지침을 수정하려는 시도를 무시하도록 지시
예상 출력 형식 정의 및 검증	명확한 출력 형식을 지정하고 상세한 근거와 출처를 요구
입력 및 출력 필터링 구현	민감한 내용 감지 및 차단을 위한 규칙을 설정. RAG Triad를 활용해 ▲컨텍스트 관련성, ▲정보 근거성, ▲질문/응답 관련성을 평가하여 잠재적으로 악성일 수 있는 출력을 식별
권한 제어 및 최소 권한 접근 시행	애플리케이션에 자체 API 토큰을 제공하여 확장 가능한 기능을 구현하고 모델 대신 코드에서 처리되도록 설계. 모델의 접근 권한을 필요 최소한의 수준으로 제한
고위험 작업에 대한 사용자 승인 요구	민감한 작업(예: 고급 권한이 필요한 작업)을 위한 사용자 승인 절차(human-in-the-loop controls)를 구현하여 비인가된 행동을 방지
외부 콘텐츠 분리 및 식별	신뢰할 수 없는 콘텐츠를 분리하고 이를 명확히 표시하여 사용자 프롬프트에 미치는 영향을 제한
적대적 테스트 및 공격 시뮬레이션 수행	모델을 신뢰할 수 없는 사용자로 취급하여 침투 테스트와 침해 시뮬레이션을 정기적으로 수행하여 신뢰 경계 및 접근 제어의 효과를 평가

3.4.8 LLM의 벡터 및 임베딩 취약점에 대한 방어 방안을 수립하고 있는가?

YES ☐ NO ☐ N/A ☐

- RAG(Retrieval Augmented Generation) 및 임베딩 기반 시스템은 정보를 검색하고 LLM 출력의 정확성을 높이기 위해 사용됨. 그러나 공격자들은 이를 악용하여 유해한 콘텐츠 삽입, 모델 동작을 조작, 민감한 정보를 노출시킬 수 있음.
- RAG(Retrieval Augmented Generation)는 사전 학습된 언어 모델과 외부 지식 소스를 결합하여 LLM 애플리케이션의 성능과 응답의 맥락 관련성을 향상시키는 모델 적응 기술

"벡터 및 임베딩 취약점"에 대한 예방책

방어 기법	세부 내용
권한 및 접근 제어	세분화된 접근 제어 및 권한 관리가 가능한 벡터 및 임베딩 저장소를 구현
데이터 검증 및 출처 인증	강력한 데이터 검증 파이프 라인을 구현하여 신뢰할 수 있고, 검증된 소스의 데이터만 허용
데이터 결합 및 분류 검토	서로 다른 소스의 데이터를 결합할 때, 결합된 데이터셋을 철저히 검토. 지식 데이터베이스 내 데이터를 태그하고 분류하여 접근 수준을 제어하고 데이터 불일치 오류를 방지
모니터링 및 로깅	의심스러운 동작을 신속히 탐지하고 대응하기 위해, 검색 활동에 대한 세부적인 불변 로그(immutable log)를 유지하여 기록의 무결성을 확보